

INICIAR SESIÓN CON CONTROL DE INTENTOS FALLIDOS

Un usuario registrado ingresa sus credenciales para acceder al sistema. El sistema valida la identidad y aplica un bloqueo temporal de la cuenta tras alcanzar el límite de intentos fallidos consecutivos permitidos.

ACTORES	REQUISITO
• Usuario registrado (Estudiante, Bibliotecario o Administrador) • Sistema de autenticación	RF_12 – Inicio de sesión con control de intentos fallidos. El sistema debe permitir el inicio de sesión a usuarios registrados y con cuenta activa, contabilizar los intentos fallidos consecutivos y bloquear temporalmente la cuenta al alcanzar el límite máximo permitido, notificando al usuario en cada paso.

DESCRIPCIÓN

Este caso de uso describe el proceso de autenticación de un usuario registrado en el sistema de la Biblioteca CyT. El usuario ingresa su correo institucional y contraseña; el sistema verifica las credenciales contra la base de datos. Si son incorrectas, el sistema incrementa un contador de intentos fallidos asociado a la cuenta. Al superar el límite de 5 intentos fallidos consecutivos, la cuenta queda bloqueada temporalmente por 30 minutos, impidiendo nuevos intentos de acceso durante ese período. Si las credenciales son correctas, el contador se reinicia y el usuario accede al sistema con los permisos correspondientes a su rol.

PRECONDICIONES

- El usuario tiene una cuenta registrada en el sistema con estado 'activa' (verificada mediante enlace de correo, RF_11).
- La cuenta del usuario no se encuentra actualmente bloqueada por intentos fallidos previos.

FLUJO NORMAL

1. El usuario accede a la pantalla principal del sistema y selecciona la opción 'Iniciar sesión'.
2. El sistema muestra el formulario de inicio de sesión con los campos: correo institucional y contraseña.
3. El usuario ingresa su correo institucional (@unal.edu.co) y su contraseña, luego presiona 'Ingresar'.
4. El sistema verifica que el correo exista en la base de datos y que la cuenta tenga estado 'activa'.
 - a. Si el correo no existe o la cuenta está en estado 'pendiente de verificación', el sistema muestra: "Credenciales incorrectas. Verifica tu correo y contraseña." y no continúa. → Vuelve al paso 3.
 - b. Si la cuenta está en estado 'expirado', el sistema informa que el enlace de

activación venció e invita al usuario a registrarse nuevamente.

5. El sistema valida que la contraseña ingresada coincida con el hash almacenado para esa cuenta.
 - a. Si la contraseña es incorrecta, el sistema incrementa en uno el contador de intentos_fallidos de la cuenta.
 - b. El sistema evalúa el nuevo valor del contador:
 - Si intentos_fallidos < 5: el sistema muestra "Credenciales incorrectas. Te quedan X intentos antes del bloqueo." → Vuelve al paso 3.
 - Si intentos_fallidos = 5: el sistema bloquea la cuenta por 30 minutos, registra la fecha y hora del bloqueo, y muestra: "Tu cuenta ha sido bloqueada temporalmente por 30 minutos debido a múltiples intentos fallidos. Intenta de nuevo más tarde o recupera tu contraseña." El flujo termina.
6. El sistema verifica que la cuenta no esté bloqueada (intentos_fallidos >= 5 y bloqueo vigente).
 - a. Si la cuenta está bloqueada y el tiempo de bloqueo no ha expirado, el sistema muestra el tiempo restante de bloqueo y no permite el acceso. El flujo termina.
 - b. Si el bloqueo ya expiró, el sistema reinicia el contador de intentos_fallidos a 0 y permite continuar.
7. El sistema autentica al usuario: reinicia el contador de intentos_fallidos a 0 y genera una sesión activa con los permisos del rol asignado (Estudiante, Bibliotecario o Administrador).
8. El sistema redirige al usuario al panel principal correspondiente a su rol.
9. El sistema registra el inicio de sesión exitoso en el log de operaciones con timestamp, usuario e IP de origen.

POSTCONDICIONES

- Si el inicio de sesión fue exitoso: el usuario tiene una sesión activa con permisos según su rol, y el contador de intentos_fallidos queda en 0.
- Si el inicio de sesión falló sin llegar al límite: el contador de intentos_fallidos se ha incrementado en uno y la cuenta sigue activa.
- Si se alcanzó el límite de intentos: la cuenta queda con estado 'bloqueada' con timestamp de bloqueo registrado.
- En todos los casos, el evento queda registrado en el log de operaciones del sistema con timestamp, identificador de usuario e IP de origen.

NOTAS

- El límite de intentos fallidos es de 5 intentos consecutivos. El contador se reinicia únicamente tras un inicio de sesión exitoso o tras la expiración del bloqueo de 30 minutos.
- El mensaje de error ante credenciales incorrectas es deliberadamente genérico (no especifica si el error es en el correo o en la contraseña) para evitar que un atacante identifique correos registrados en el sistema.
- El bloqueo es temporal (30 minutos). Pasado ese tiempo, la cuenta se desbloquea automáticamente sin intervención del administrador. El Administrador puede levantar el bloqueo manualmente si el usuario lo solicita.
- La verificación de la contraseña debe comparar contra el hash almacenado (bcrypt o equivalente). Nunca se almacena ni se compara la contraseña en texto plano.
- Este caso de uso aplica a todos los roles del sistema: Estudiante, Bibliotecario y Administrador. El sistema redirige a un panel distinto según el rol autenticado.

MOCKUP

Los tres escenarios del flujo de autenticación: formulario inicial sin errores (A), advertencia de intentos restantes tras credenciales incorrectas (B) y pantalla de cuenta bloqueada con temporizador de desbloqueo (C).

Biblioteca CyT · UNAL Iniciar sesión Correo institucional usuario@unal.edu.co Contraseña ●●●●●●●● Ingresar ¿Olvidaste tu contraseña? Escenario A – Formulario inicial	Biblioteca CyT · UNAL Iniciar sesión Correo institucional jcristiano@unal.edu.co Contraseña ●●●●●●●● ⚠ Credenciales incorrectas. Te quedan 2 intentos antes del bloqueo de tu cuenta. Ingresar ¿Olvidaste tu contraseña? Escenario B – Advertencia (3 de 5 intentos)	Biblioteca CyT · UNAL Iniciar sesión Correo institucional jcristiano@unal.edu.co Contraseña ●●●●●●●● 🔒 Tu cuenta ha sido bloqueada temporalmente por 30 minutos. Tiempo restante: 27:43. Intenta de nuevo más tarde o recupera tu contraseña. Ingresar (bloqueado) Recuperar contraseña Escenario C – Cuenta bloqueada (5/5 intentos)
--	--	--

Estados: ■ Campo normal ■ Campo con error ■ Advertencia ■ Cuenta bloqueada